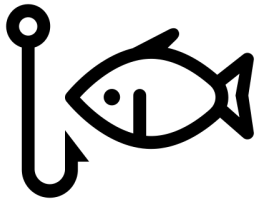


Web3 钓鱼手法解析

Thinking@slowmist.com & Cos@slowmist.com



Web3 钓鱼攻击现状与防御挑战



攻击现状

攻击者通常选择热度高的项目进行精心伪装，通过空投、高回报等诱饵吸引用户。手法包括域名仿冒、社交媒体欺诈、虚假应用程序等。攻击者擅长运用社会工程学，通过"明修栈道，暗度陈仓"的策略隐藏真实意图。



防御挑战

用户难以持续保持高度警惕，即使安全意识较强也可能遭受攻击。攻击手法不断创新，识别真伪难度大。攻击者善于隐匿身份并清除证据，增加了追踪难度。

1 伪
2 饵
3 诱
4 攻
5 隐
6 技
7 斡
8 御





披沙拣金：筛选目标项目并进行伪装

攻击者通过调研近期趋势热度的方向，热点项目方的社区活跃情况，以及目标项目的用户规模等，筛选出“关注度高”的热点项目，并构建伪装。

伪装包括：

- 相似~~(真实)~~的域名和网页
- 相似~~(真实)~~的社交媒体账号或 TG Bot
- 相似~~(真实)~~的管理员马甲
- .....

明修栈道：吸引流量（ ）的手段

在 Web3 领域，“明修栈道，暗度陈仓”的手法被广泛运用。

表面上攻击者伪装项目方通过发布 AMA、空投等活动吸引流量，实则借此分发“饵料”，为后续的钓鱼攻击做准备，让用户防不胜防。

伪装身份：可能是伪装项目官方社交媒体账号，应用程序，Web 站点，TG Bot 等，也可能是知名的 Web3 KOL 等。

暗度陈仓：隐藏攻击的智慧



攻击者最终的意图：盗取资产 / 盗取权限 -> 盗取资产

由于有前面的铺垫，用户安全意识较差的就容易在后续的攻击意图中"中招"，安全意识较高的也难免"常在岸边走哪有不湿鞋"，实时保持最高的警惕性很难。

暗度陈仓：隐藏攻击的智慧

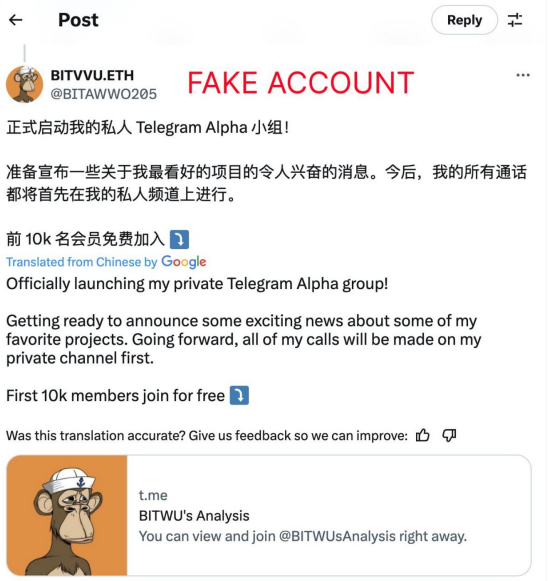
攻击会将真实的意图进行隐藏：

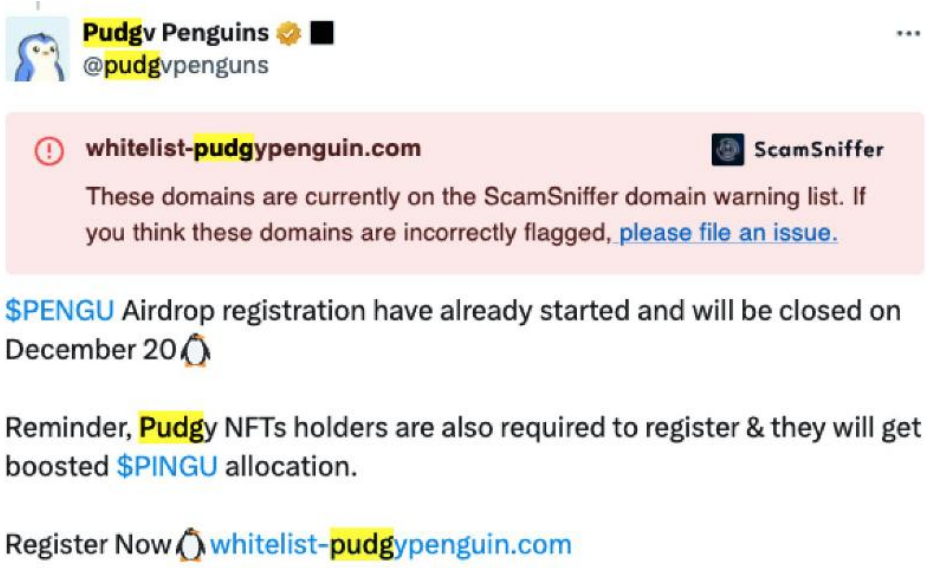
- 盗取用户助记词私钥，如：欺骗用户输入助记词或私钥等
- 欺骗用户使用钱包签名，如：授权签名，转账签名等
- 盗取用户账号密码，如：Telegram，Gmail，X，Discord 等
- 盗取用户社交应用权限：如：X，Discord 等
- 诱导安装恶意程序，如：假钱包 APP，假社交 APP，假会议 APP 等
- ……



创建饵料：好康（有利可图）

攻击者构建"好康"的饵料





创建饵料：好康（有利可图）

构建话术为饵料推广，诱导交互赋予故事

- 让用户觉得有利可图，如：Airdrop 资格白名单，挖头矿，财富密码等
- 给予用户方便，如：薅空投工具，AI 量化工具，一键挖矿薅羊毛等

投放饵料：精准覆盖的策略

投放渠道

- 社交 APP：X，Telegram，Discord 等
- 搜索引擎：Google，Baidu，Bing 等
- 邮箱：SMTP Server(Google，AWS) 批量邮件分发等
- ~~APP 商城：Google Play，Chrome Store，App Store，APKCombo 等~~



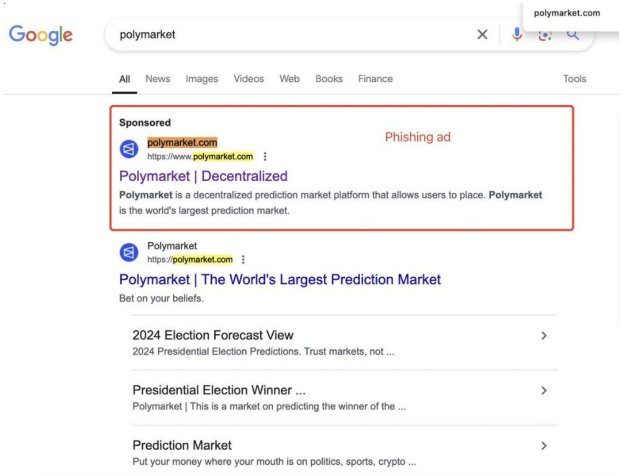
传播诱饵：在社交媒体/搜索引擎排名中传播

攻击者利用 Web3 社群在 Web3 社交媒体上发布诱人的 ~~Token Airdrop 活动链接~~，引诱用户点击访问，从而开始“演绎剧本故事”，通常会以完成一系列任务才能够获得奖励等话术，诱导用户“上钩”。

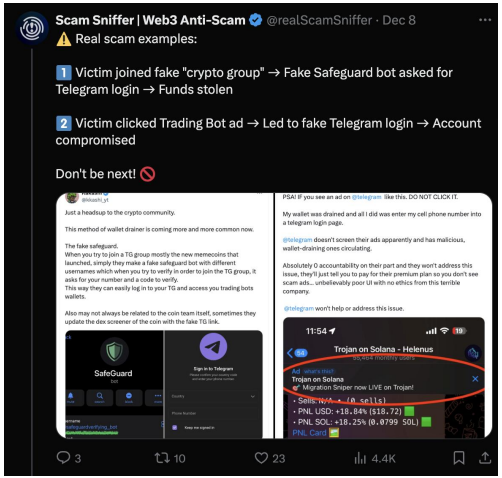
投放方式

- 社交平台：群聊，私信，评论留言，发 tweet，打广告等
- 搜索引擎：SEO / 打广告刷排名
- ~~APP 商城：上架仿冒 APP 或虚假 APP~~

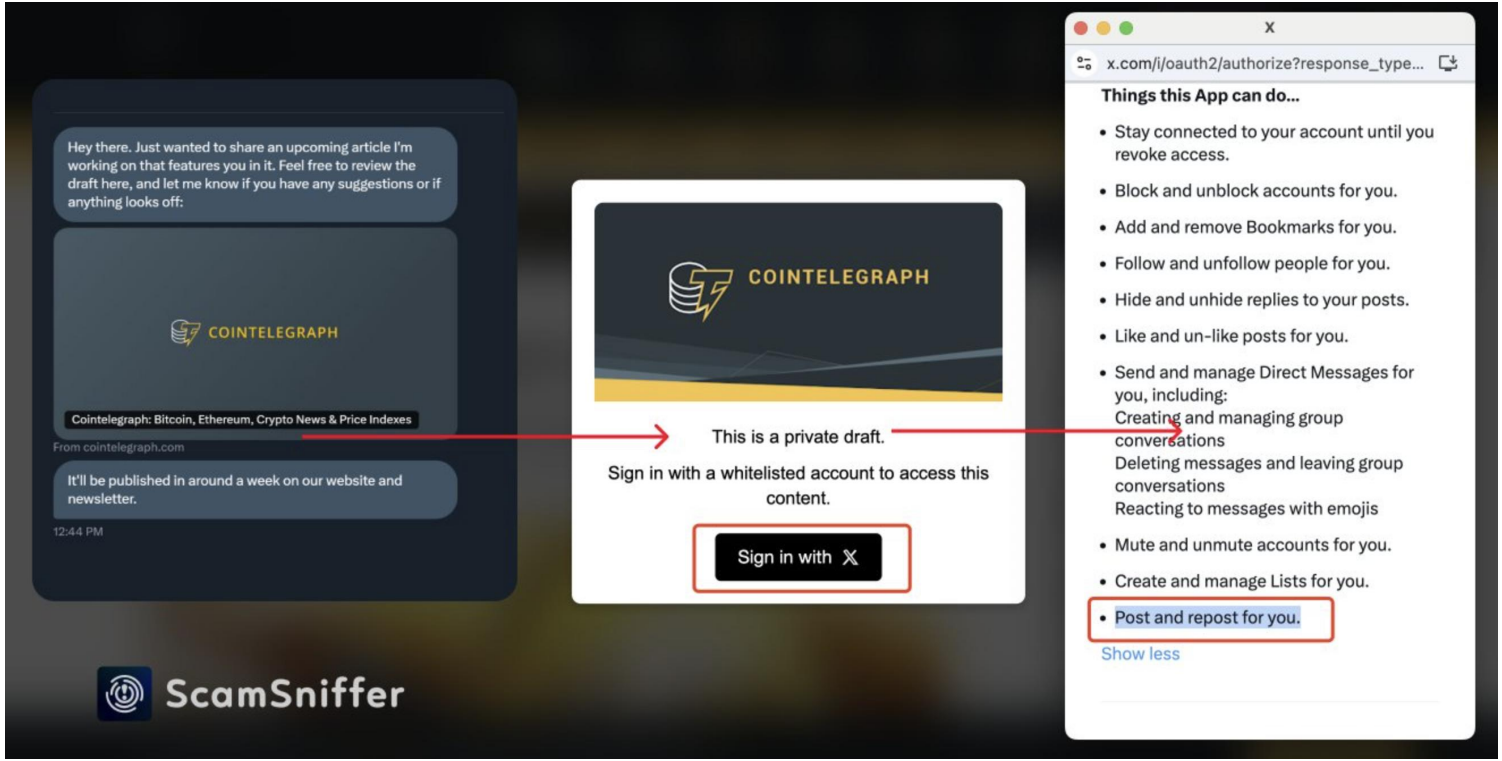
传播诱饵：在社交媒体/搜索引擎排名中传播



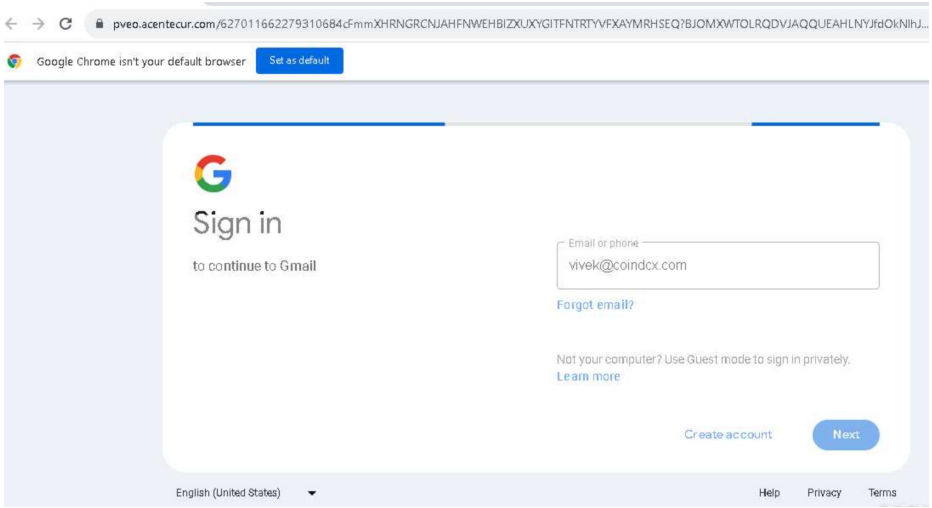


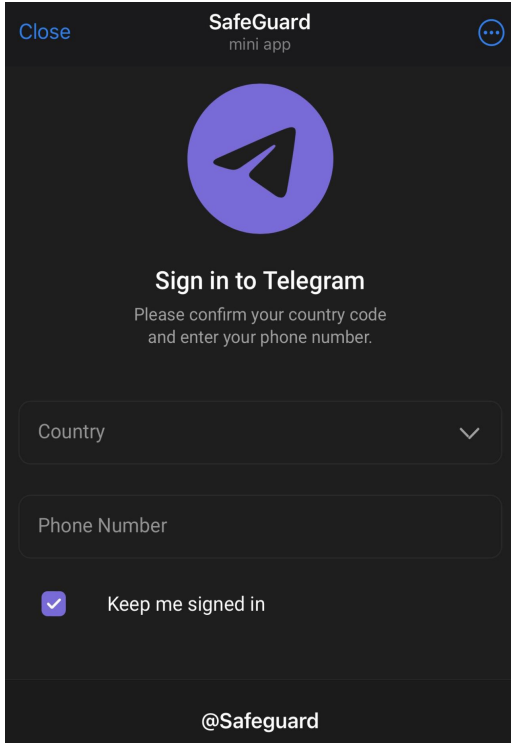


引导诱骗：社会工程学--让用户在无意中掉入陷阱



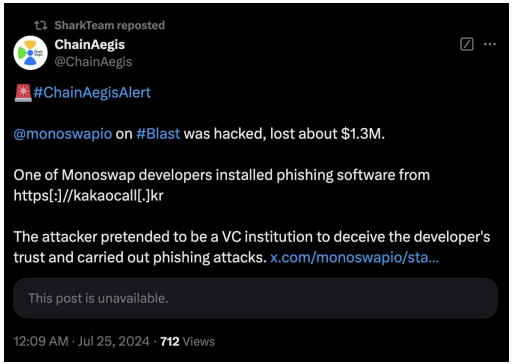
引导诱骗：社会工程学--让用户在无意中掉入陷阱





引导诱骗：社会工程学--让用户在无意中掉入陷阱





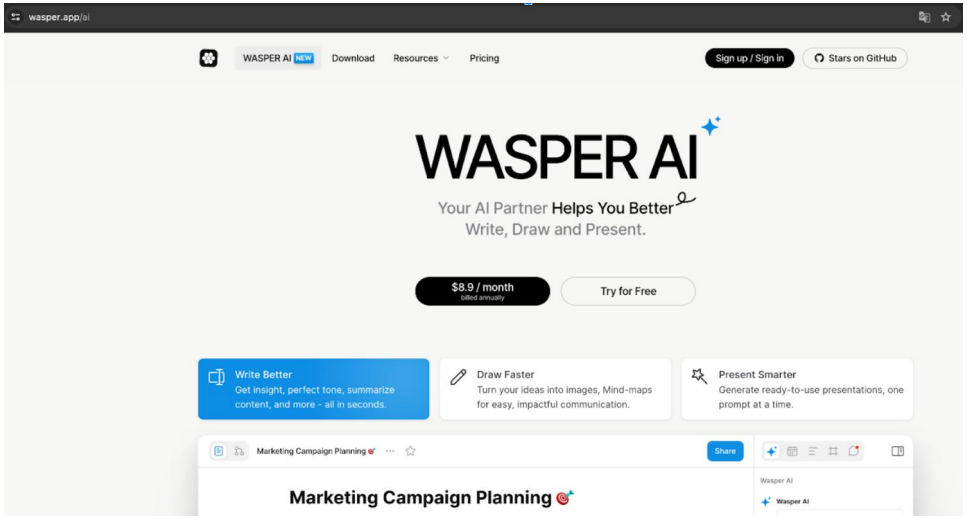




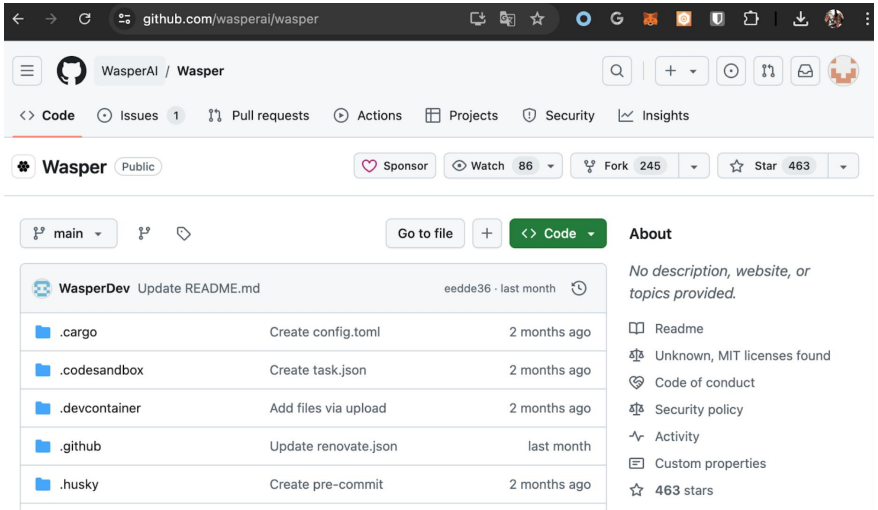
引导诱骗：社会工程学--让用户在无意中掉入陷阱

黑客通过和受害者在社交平台上聊天，向用户推荐"优质"项目，引导受害者访问恶意的钓鱼站点 https[:]//wasper[.]app，下载恶意的应用程序。





引导诱骗：社会工程学--让用户在无意中掉入陷阱



Contributing

Bug Reports	Feature Requests	Questions
Create a bug report	Submit a feature request	Send us an Email
Something isn't working as expected	An idea for a new feature, or improvements	contact@wasper.app

Calling all developers, testers, tech writers and more! Contributions of all types are more than welcome, you can read more in docs/types-of-contributions.md. If you are interested in contributing code, read our docs/CONTRIBUTING.md and feel free to check out our GitHub issues to get stuck in to show us what you're made of.

Before you start contributing, please make sure you have read and accepted our Contributor License Agreement. To indicate your agreement, simply edit this file and submit a pull request.

For **bug reports**, **feature requests** and other **suggestions** you can also create a new issue and choose the most appropriate template for your feedback.

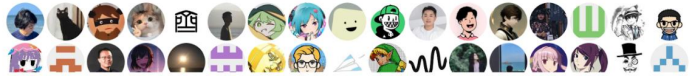
If you have questions, you are welcome to contact us. One of the best places to get more info and learn more is in the Wasper where you can engage with other like-minded individuals.

Ecosystem

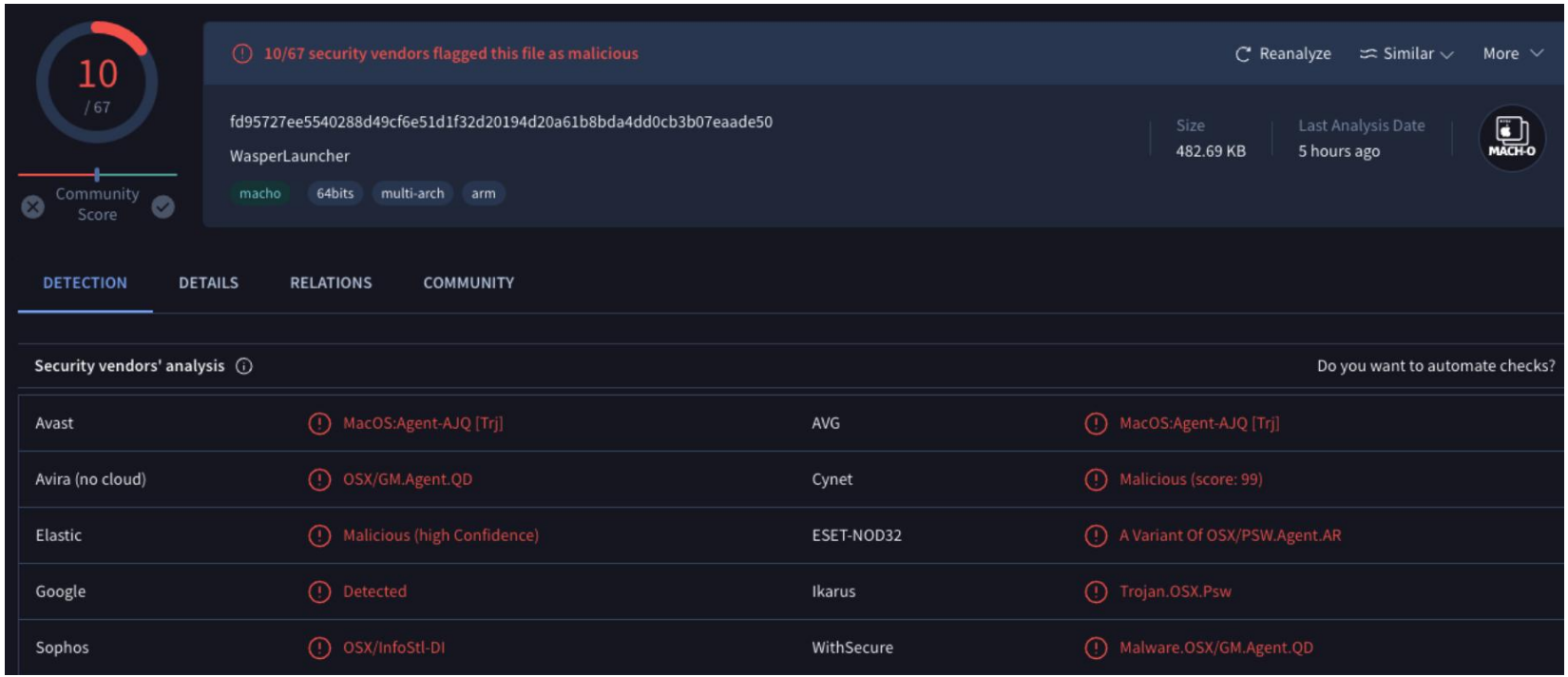
Name		
@wasper/component	Wasper Component Resources	coverage 58%
@wasperai/theme	Wasper theme	downloads 28k/month

Contributors

We would like to express our gratitude to all the individuals who have already contributed to Wasper! If you have any Wasper-related project, documentation, tool or template, please feel free to contribute it by submitting a pull request to our curated list on GitHub: awesome-Wasper.



引导诱骗：社会工程学--让用户在无意中掉入陷阱





攻其不备：趁虚而入的时机->让目标"起心动念"

- 好奇/贪婪

  无惧卖飞的逃顶策略，不容错过潜在 100 倍币，今晚 10 点不见不散，会议链接 https://us04-zoom.us/

- 好奇/贪婪

  $PENGU 空投白名单不容错过，https://vote-pengu.com/

- 恐惧

  紧急告警：XX 项目被黑，请使用 revake.cash 取消授权避免资金损失

……





隐匿行踪：隐藏网络身份



VPN



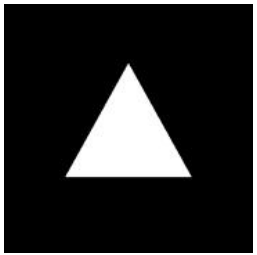
Tor



Zombie

隐匿行踪：匿名采购服务或基础设施


Namecheap


Vercel



Netlify


Cloudflare

隐匿行踪：混币藏匿资金转移路径



Wasabi Wallet



TornadoCash



Monero

扫清痕迹：获利后避免留下样本和证据

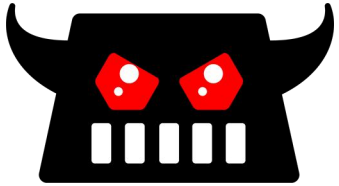
- 删除相关域名解析
- 删除恶意程序
- 删除相关的记录（GitHub 仓库，平台账号等）



常用渔具：捕鱼的工具



Gophish



Evilginx



Evilgophish



Swaks



DNSTwist



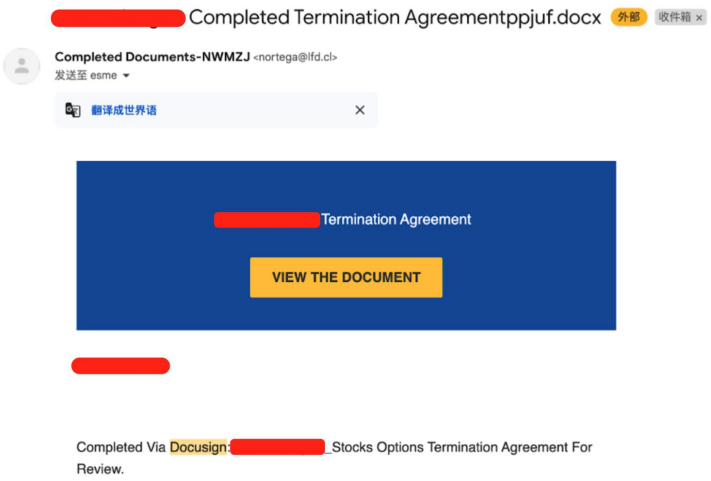
BlackEye

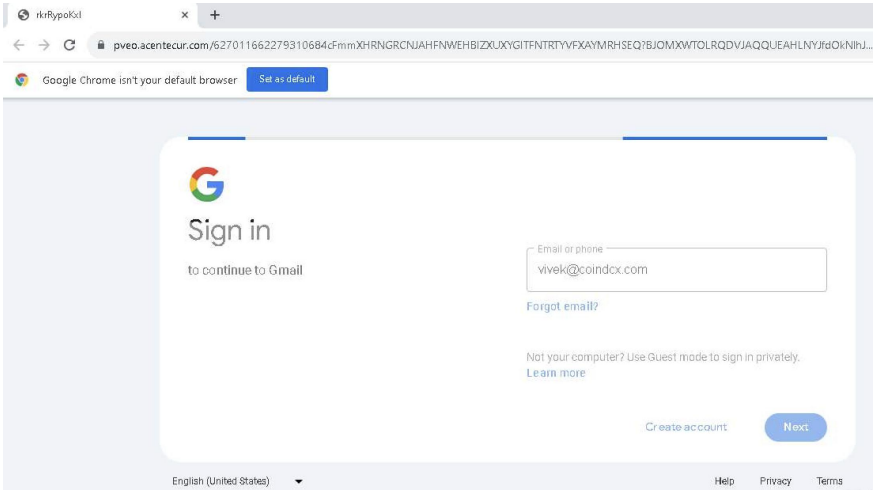
朴实无华：钓鱼模板 + 反向代理

shuvo-halder Add files via upload — d110666 · 2 months ago

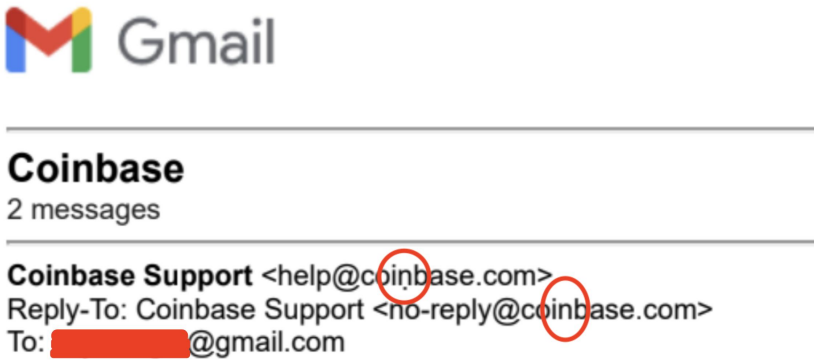
Name	Last commit message	Last commit date
..		
adobe	Add files via upload	2 months ago
amazon	Add files via upload	4 years ago
apple	Add files via upload	2 months ago
badoo	Add files via upload	4 years ago
bitcoin	Add files via upload	4 years ago
create	Add files via upload	4 years ago
devianart	Add files via upload	4 years ago
dropbox	Add files via upload	4 years ago
facebook	Add files via upload	4 years ago
github	Add files via upload	4 years ago
gitlab	Add files via upload	4 years ago
google	Add files via upload	4 years ago
icloud	Add files via upload	4 years ago
instafollowers	Add files via upload	4 years ago
instagram	Add files via upload	4 years ago
linkedin	Add files via upload	4 years ago
messenger	Add files via upload	4 years ago
microsoft	Add files via upload	4 years ago
myspace	Add files via upload	4 years ago
netflix	Add files via upload	4 years ago
origin	Add files via upload	4 years ago
paypal	Add files via upload	4 years ago
pinterest	Add files via upload	4 years ago
playstation	Add files via upload	4 years ago
protonmail	Add files via upload	4 years ago
shopify	Add files via upload	4 years ago
shopping	Add files via upload	4 years ago
snapchat	Add files via upload	4 years ago
spotify	Add files via upload	4 years ago
steam	Add files via upload	4 years ago
twitch	Add files via upload	4 years ago
twitter	Add files via upload	4 years ago
verizon	Add files via upload	4 years ago
vk	Add files via upload	4 years ago
wifi	Add files via upload	4 years ago

朴实无华：钓鱼模板 + 反向代理



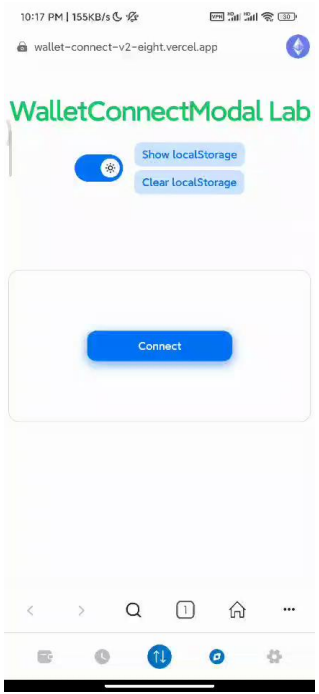


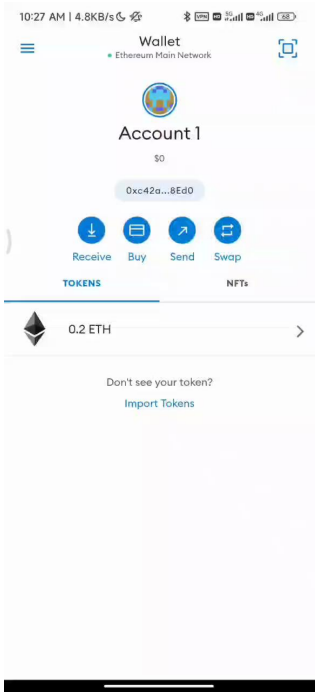
视觉欺骗：相似域名与邮箱伪造

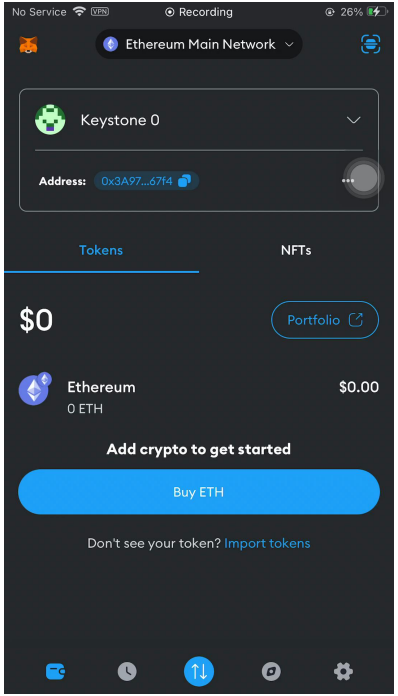




巧用缺陷：利用 Web3 钱包的缺陷

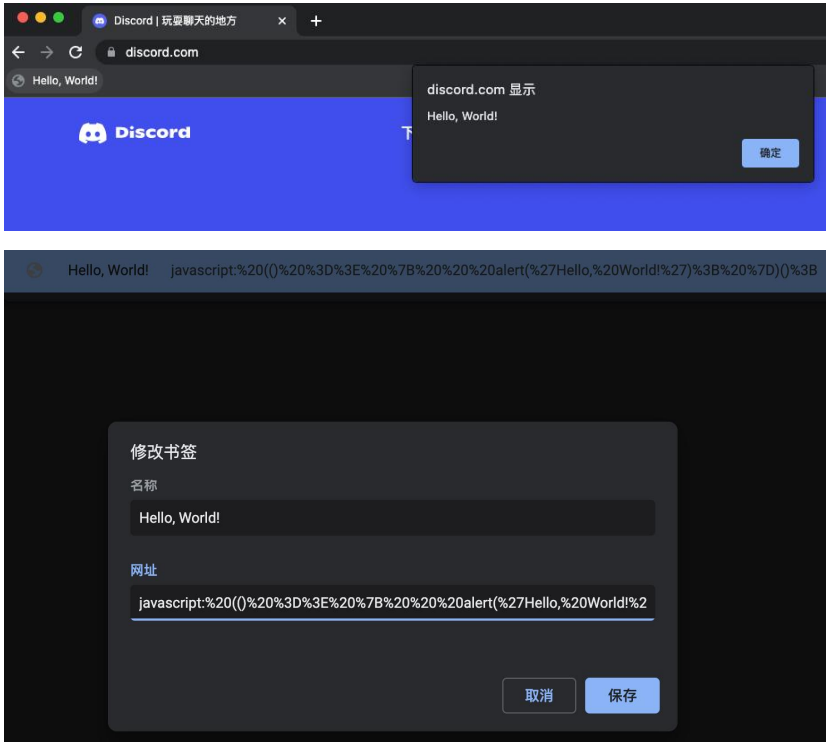






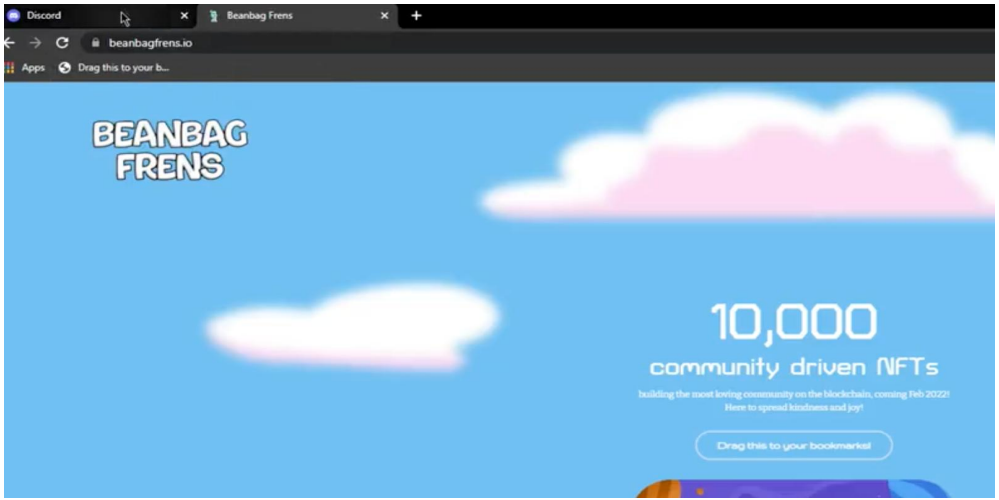
更多案例

浏览器特性：书签钓鱼

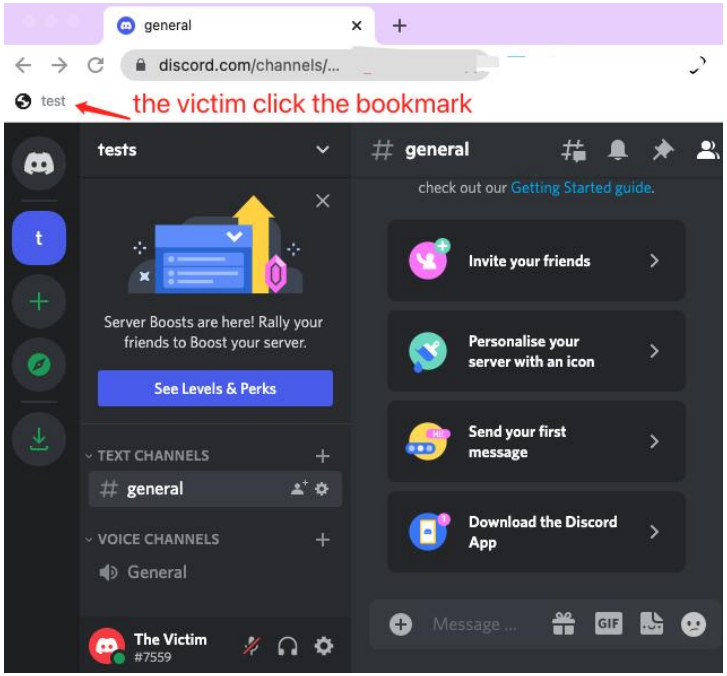

Discord | 玩耍聊天的地方
discord.com
Hello, World!
Discord
discord.com 显示
Hello, World!
确定
Hello, World!
javascript:%20(()%20%3D%3E%20%7B%20%20%20alert(%27Hello,%20World!%27)%3B%20%7D)()%3B
修改书签
名称
Hello, World!
网址
javascript:%20(()%20%3D%3E%20%7B%20%20%20alert(%27Hello,%20World!%2
取消
保存

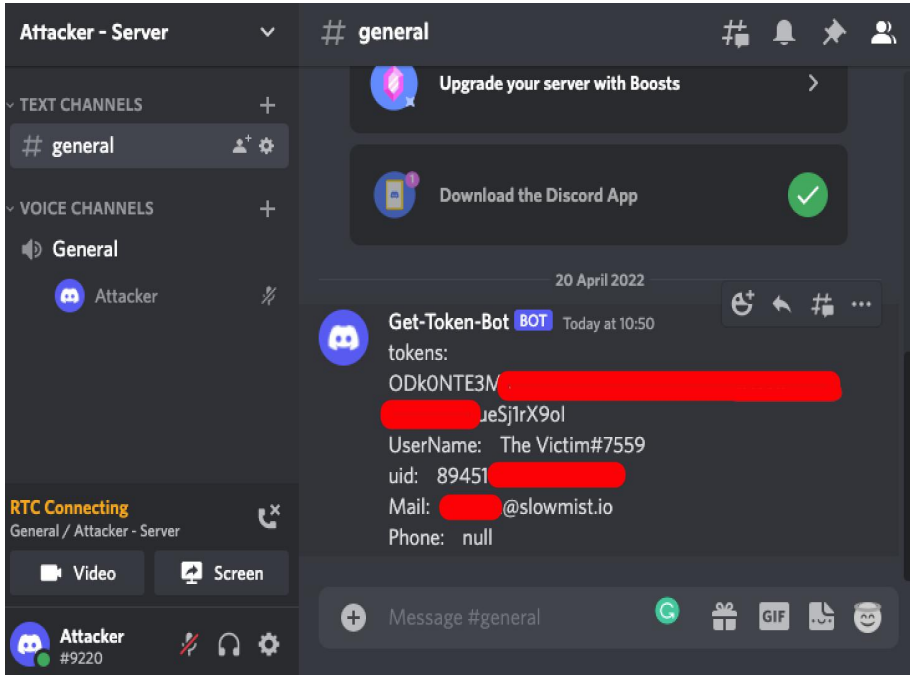
浏览器特性：书签钓鱼


/bookmark.html
Hello, World!
Hello, World!
javascript: (() => { alert('Hello, World!'); })();
Hello, World!


Discord
Beanbag Frens
beanbagfrens.io
Apps
Drag this to your b...
BEANBAG FRENS
10,000
community driven NFTs
building the most loving community on the blockchain, coming Feb 2022!
Here to spread kindness and joy!
Drag this to your bookmarks!

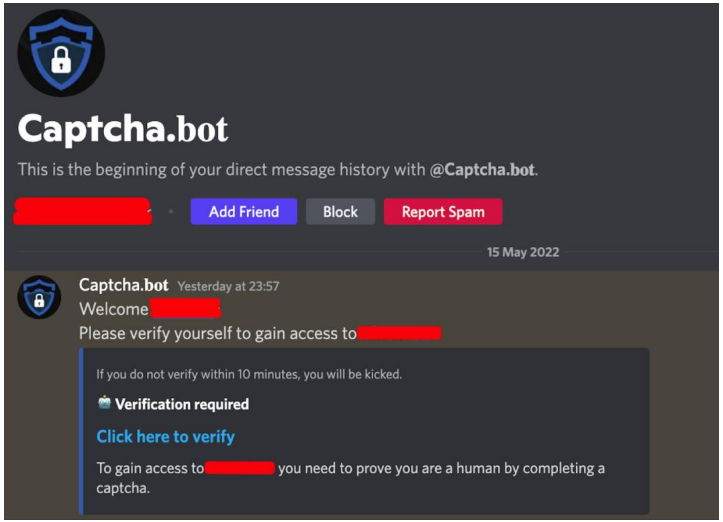
浏览器特性：书签钓鱼

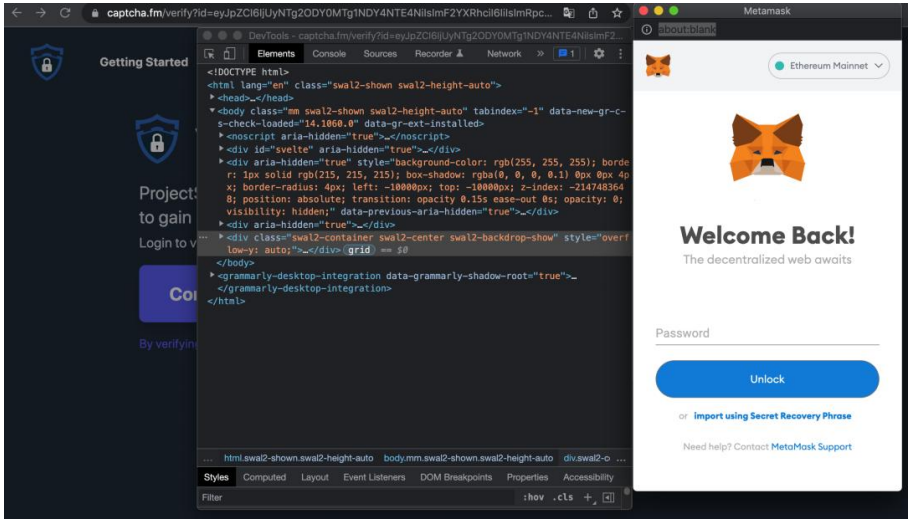




(慢雾出品: 揭露浏览器恶意书签如何盗取你的 Discord Token)

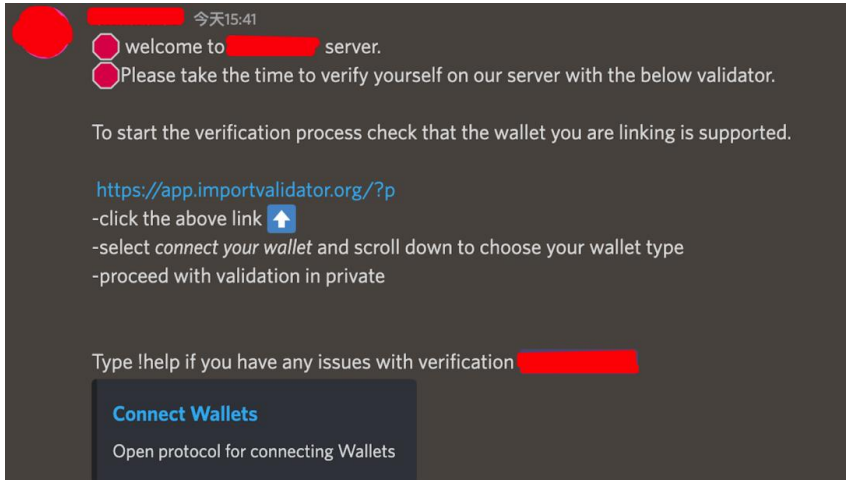
私信钓鱼：虚假人机验证 bot

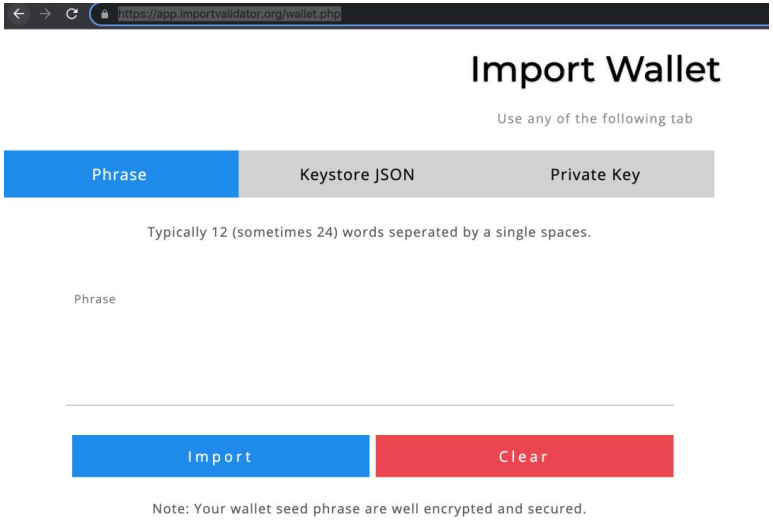




(慢雾出品: Discord 私信钓鱼手法分析)

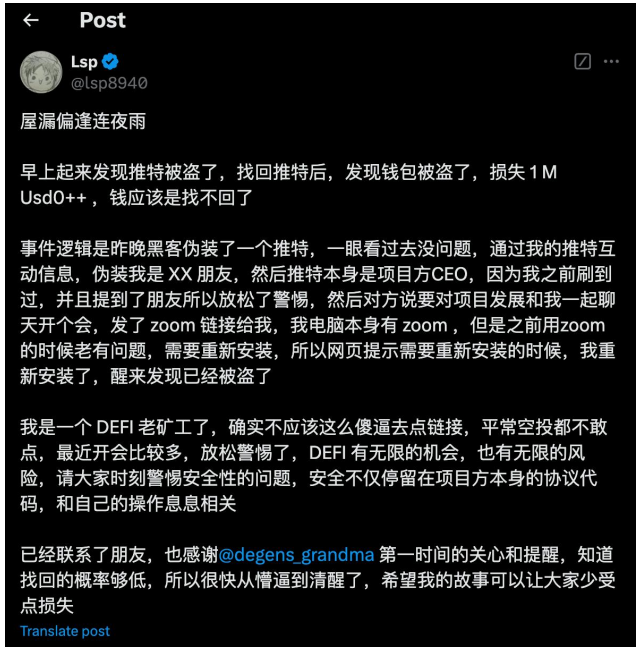
私信钓鱼：虚假官方账号





(慢雾出品: Discord 私信钓鱼手法分析)

私信钓鱼：发送虚假会议 APP(恶意程序)





(https://x.com/lsp8940/status/1871350801270296709)

(https://x.com/bocaibocai_/status/1841731741175971891)

(慢雾出品: 眼见不为实丨假 Zoom 会议钓鱼分析)


判律

如何分辨是否正在遭受钓鱼攻击？

基本验证

- 验证官方域名
- 验证官方项目方社交媒体账号
- 通过多个可靠渠道交叉验证信息
- 查看社区讨论和评价
- 使用区块链浏览器查看合约活动
- 使用防御工具进行验证



如何分辨是否正在遭受钓鱼攻击?

常见可疑特征:

- 承诺不合理的高回报
- 要求紧急操作或限时优惠
- 索要私钥或助记词
- 未知来源的空投诱饵
- 虚假的项目团队信息
- 要求 X 登录和授权
- 要求在电脑或手机中安装应用程序
- ……





防御工具：用好防御工具



Scam Sniffer



Rabby



AVG



Hardware Wallet

防御策略：提升安全意识，保持零信任和持续验证的习惯

- 零信任：

  保持怀疑，并且始终保持怀疑。

- 持续验证：

  相信自己有能力去验证自己怀疑的点，

  并把这种能力培养成习惯。



修行就在起心动念处，看好自己的心念，避免于境"起心动念"而不自觉

提升安全意识：熟读《区块链黑暗森林自救手册》



区块链黑暗森林自救手册

Blockchain Dark Forest Selfguard Handbook

Master these, master the security of your cryptocurrency.

➢ https://darkhandbook.io

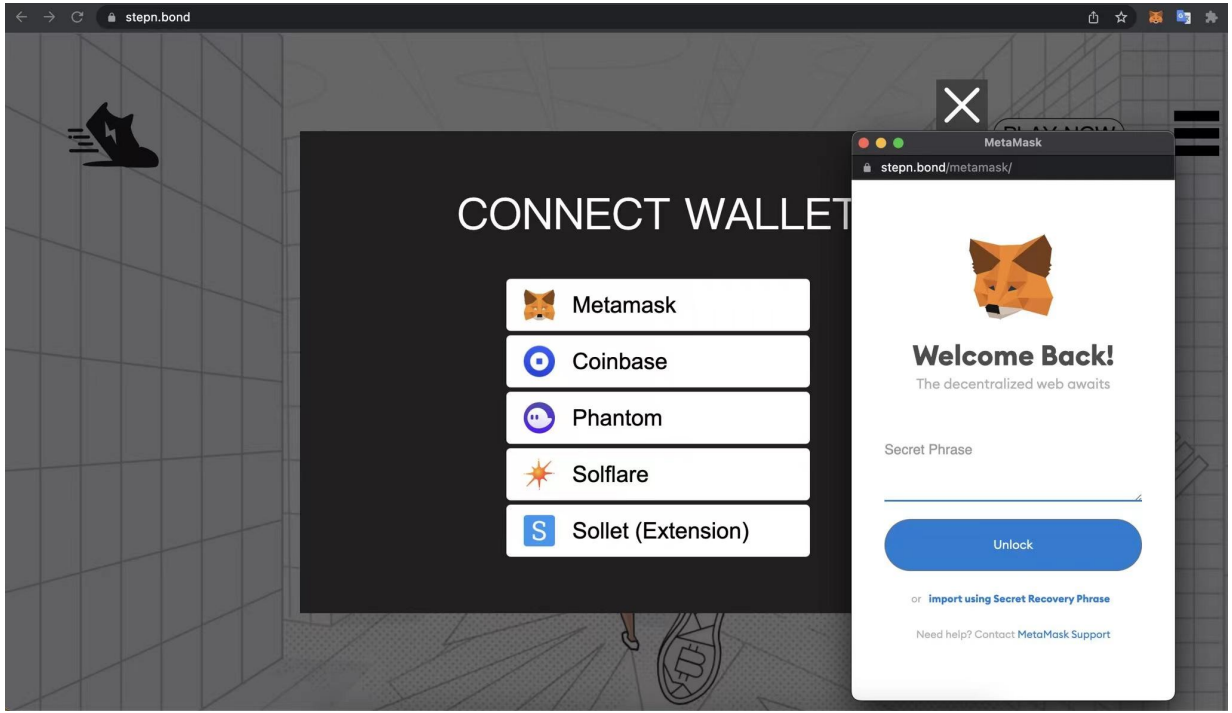
持续关注 Web3 钓鱼手法

- 慢雾出品：X 账号安全排查加固指南
- 慢雾出品：揭露浏览器恶意书签如何盗取你的 Discord Token
- 慢雾出品：Discord 私信钓鱼手法分析
- 慢雾出品：花小钱钓大鱼 | 揭秘 1155 WBTC 钓鱼事件
- 慢雾出品：黑暗"天使" —— Angel Drainer 钓鱼团伙揭秘
- 慢雾出品：加密资产安全解决方案
- 慢雾出品：眼见不为实 | 假 Zoom 会议钓鱼分析
- 慢雾出品：警惕 Web3 钱包 WalletConnect 钓鱼风险
- 慢雾出品：反向钓鱼 | 揭露利用 token 精度钓鱼的套路
- 慢雾出品：NFT 防钓鱼指北：如何选择一款防钓鱼插件
- 慢雾出品："揭开" 数千万美金大盗团伙 Monkey Drainer 的神秘面纱
- 慢雾出品：Balancer.fi BGP Hijacking 攻击分析
- 慢雾出品：保护你的钱包！假钱包全景追踪
- 慢雾出品：新型诈骗 | 警惕伪装成转账地址的钓鱼网址
- 慢雾出品：钓鱼揭秘之谷歌虚假广告钓鱼


EASTER EGG

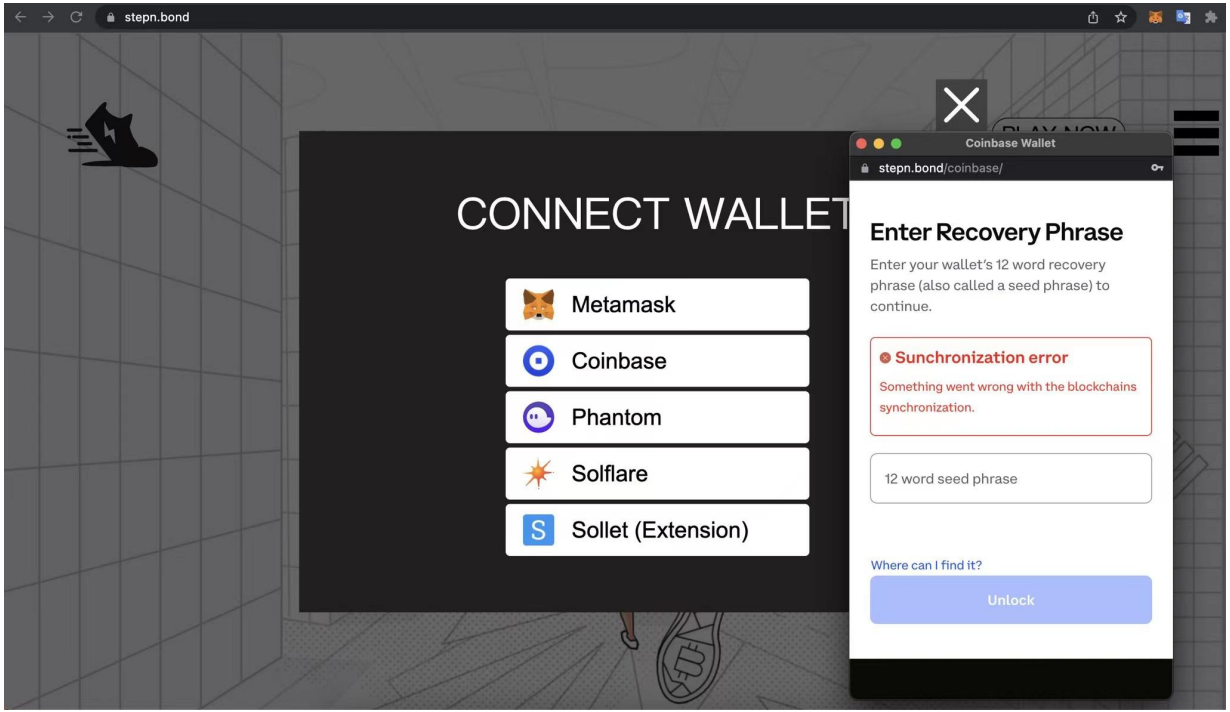
案例 1

- Phishing websites stolen Mnemonic Phrase.



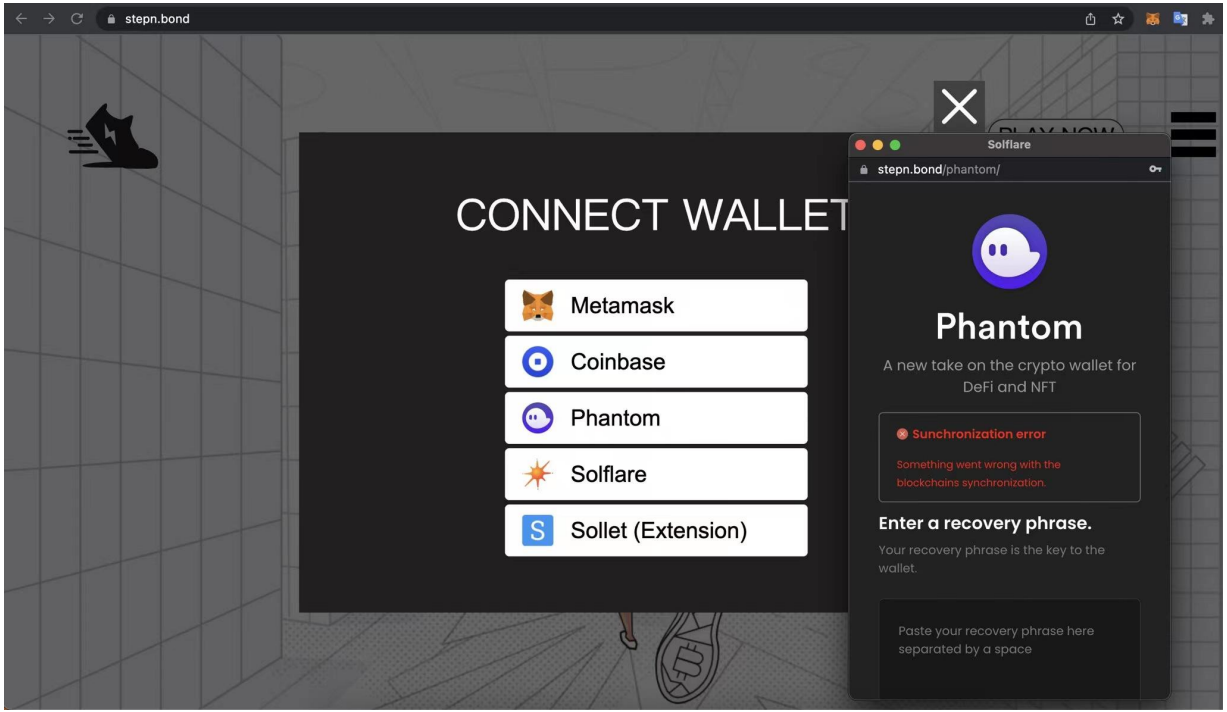
案例 1

- Phishing websites stolen Mnemonic Phrase.



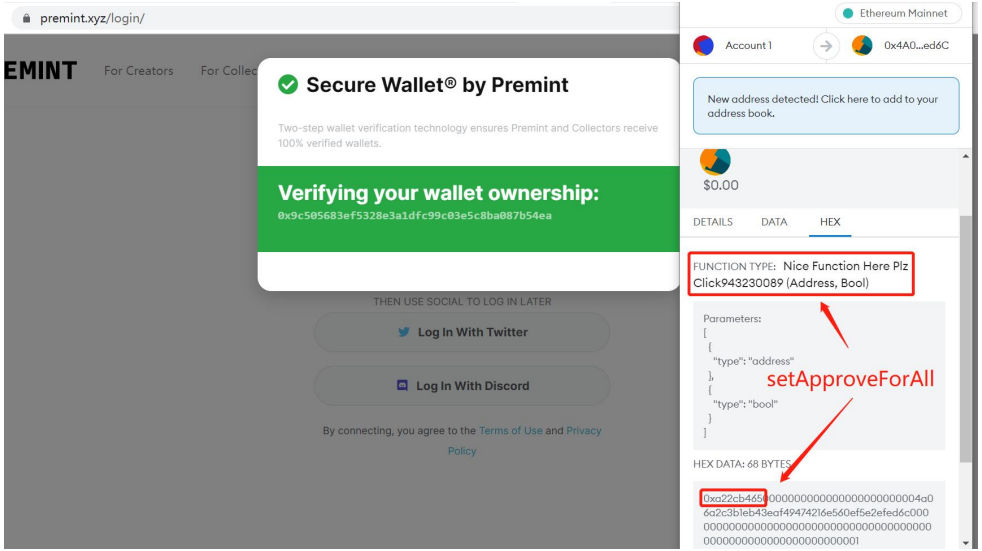
案例 1

- Phishing websites stolen Mnemonic Phrase.



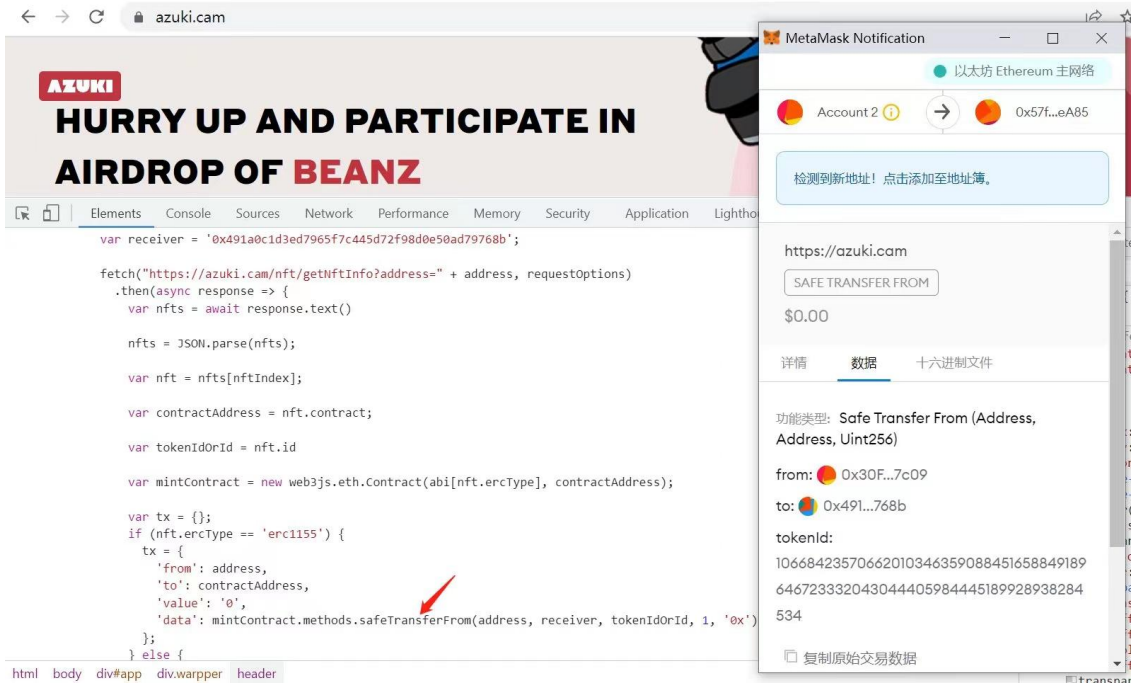
案例 2

- Approve is a common mechanism of Ethereum smart contracts(e.g., of ERC20, ERC721, ERC1155, etc).
- Phishing websites can use Approve to do the tokens theft attack.



案例 3

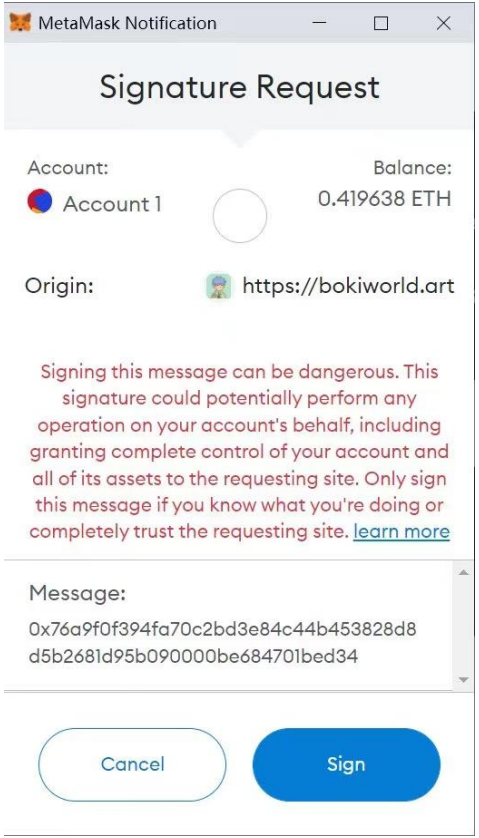
- Phishing websites can use Transfer to do the ETH/tokens theft attack.



案例 4

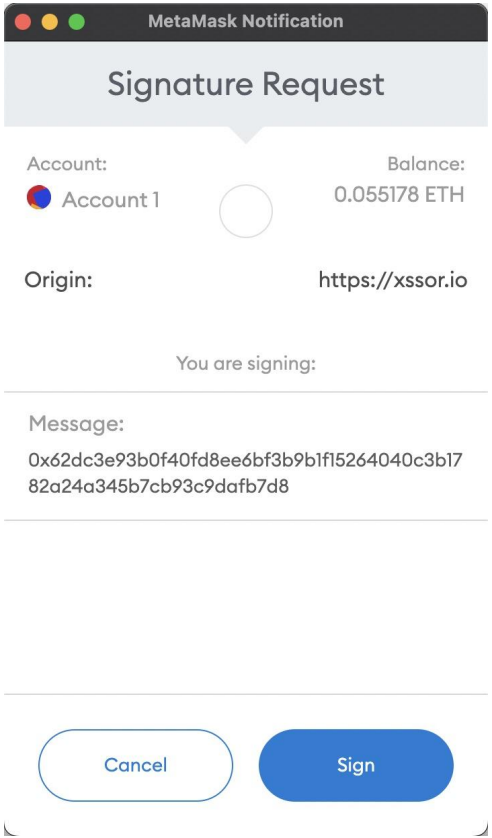
- Phishing websites can use eth_sign to do the ETH/tokens theft attack.
- eth_sign is a low-level signature method of Ethereum, and MetaMask will have a red text alert.
- For the user, the message is just a string of 66 characters beginning with 0x.
- This is a kind of blind sign.

解析：*https://mp.weixin.qq.com/s/E-LSN5eYwWhCQOH46-XyNg*



案例 5

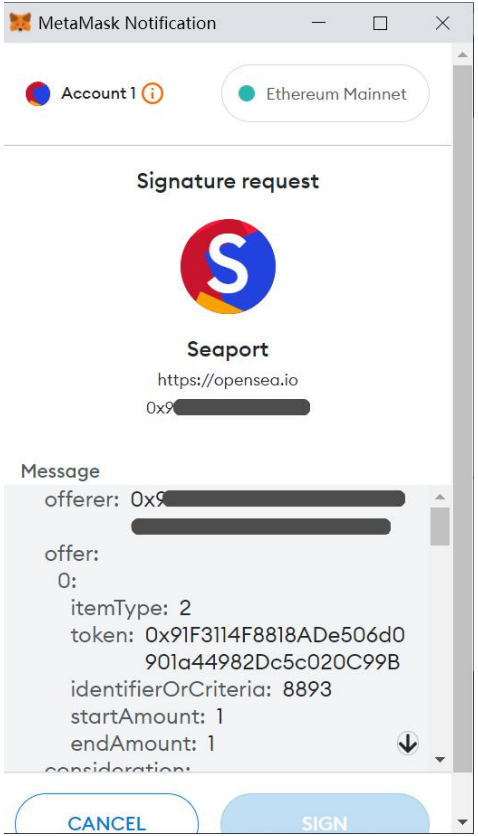
- Phishing websites can use personal_sign to do the NFTs theft attack.
- The root causes are:
  - Users signed NFT listing requests on NFT Marketplace.
  - Hackers phished to obtain relevant signatures from users.
  - Hackers stole the NFTs of users at very low cost.



案例 6

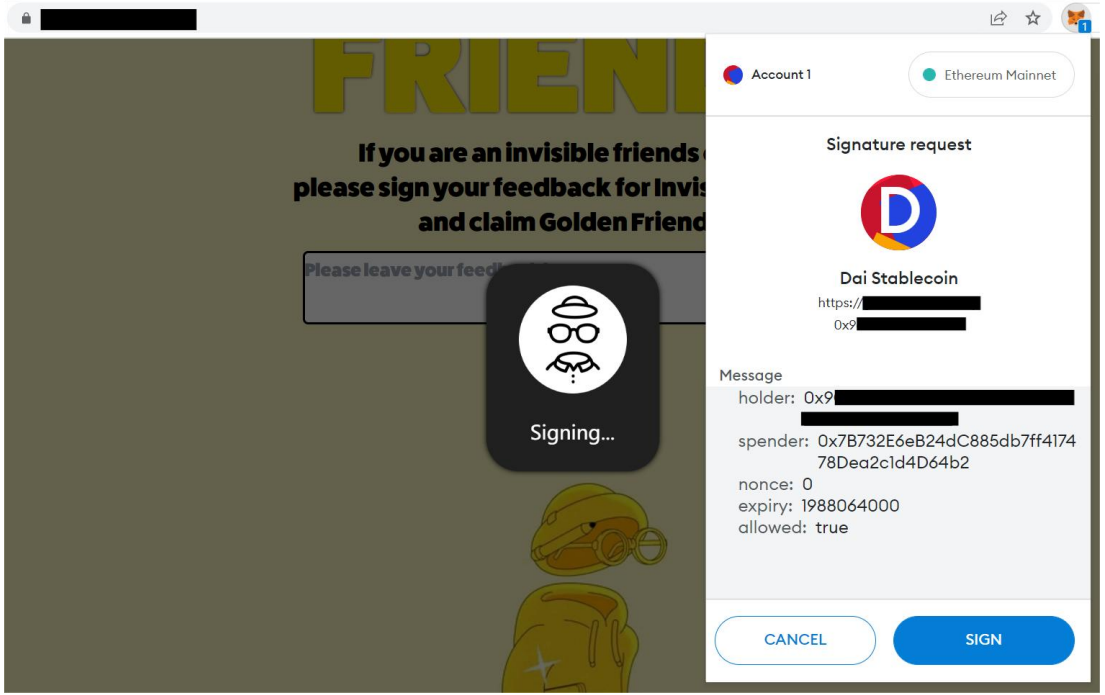
- Phishing websites can use signTypedData_v4 to do the NFTs theft attack.
- The root causes are:
  - Users signed NFT listing requests on NFT Marketplace.
  - Hackers phished to obtain relevant signatures from users.
  - Hackers stole the NFTs of users at very low cost.

解析：*https://twitter.com/evilcos/status/1578993566675742721*



案例 7

- Signature phishing against DAI/USDC
- If signed, the hacker can obtain the signature result (r, s, v values)...



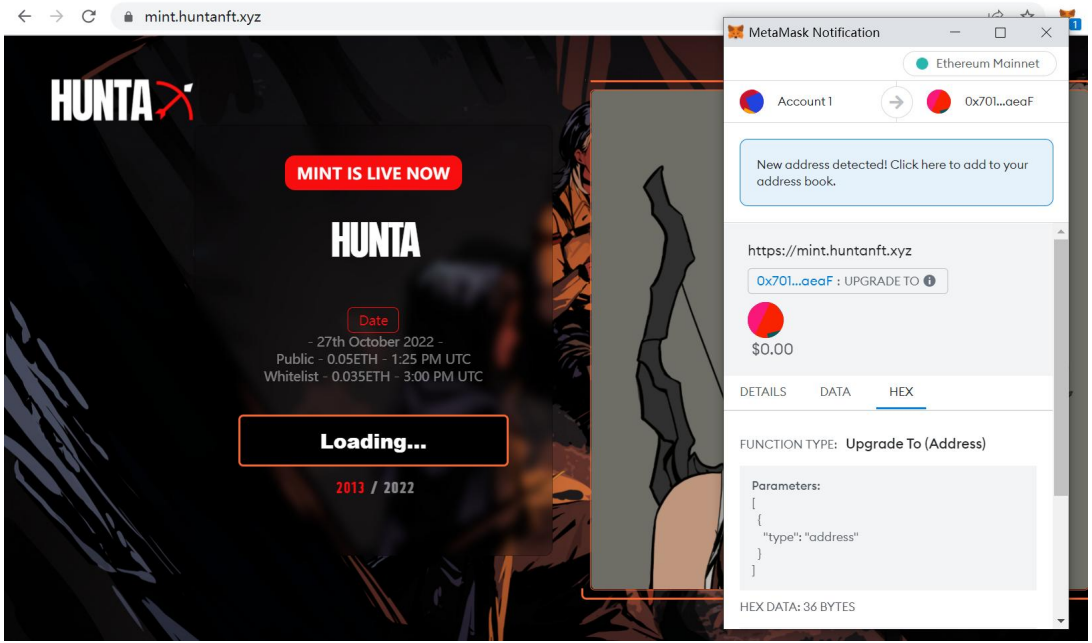
案例 7

- Call the DAI's permit function to complete authorization and coin theft:

```
170     // --- Approve by signature ---
171     function permit(address holder, address spender, uint256 nonce, uint256 expiry,
172                     bool allowed, uint8 v, bytes32 r, bytes32 s) external
173     {
174         bytes32 digest =
175             keccak256(abi.encodePacked(
176                 "\x19\x01",
177                 DOMAIN_SEPARATOR,
178                 keccak256(abi.encode(PERMIT_TYPEHASH,
179                                      holder,
180                                      spender,
181                                      nonce,
182                                      expiry,
183                                      allowed))
184         ));
185
186         require(holder != address(0), "Dai/invalid-address-0");
187         require(holder == ecrecover(digest, v, r, s), "Dai/invalid-permit");
188         require(expiry == 0 || now <= expiry, "Dai/permit-expired");
189         require(nonce == nonces[holder]++, "Dai/invalid-nonce");
190         uint wad = allowed ? uint(-1) : 0;
191         allowance[holder][spender] = wad;
192         emit Approval(holder, spender, wad);
193     }
194 }
```

案例 8

- Phishing interacting with upgradeTo of OwnableDelegateProxy of OpenSea Wyvern Protocol :-(



案例 8

- Phishing interacting with upgradeTo of OwnableDelegateProxy of OpenSea Wyvern Protocol :-(
- Set a malicious implementation address.
- Which gives the hacker permission to withdraw your NFTs.

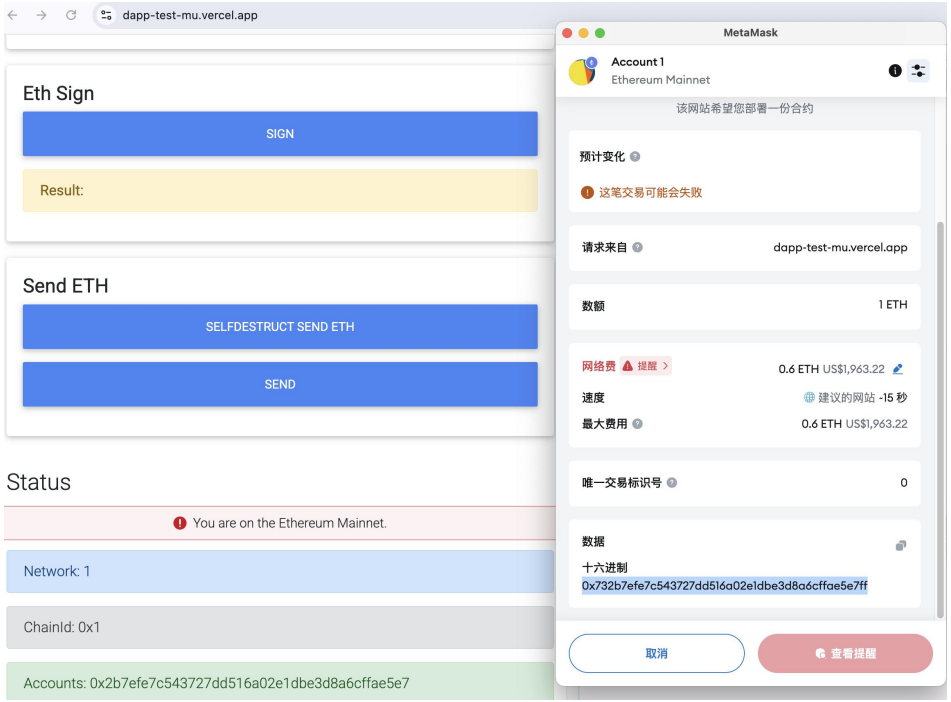
```
136     */
137   function upgradeTo(address implementation) public onlyProxyOwner {
138     _upgradeTo(implementation);
139   }
140
141   /**
142    * @dev Allows the upgradeability owner to upgrade the current implementation of the proxy
143    * and delegatecall the new implementation for initialization.
144    * @param implementation representing the address of the new implementation to be set.
145    * @param data represents the msg.data to bet sent in the low level call. This parameter may include the function
146    * signature of the implementation to be called with the needed payload
147    */
148   function upgradeToAndCall(address implementation, bytes data) payable public onlyProxyOwner {
149     upgradeTo(implementation);
150     require(address(this).delegatecall(data));
151   }
152 }
```

案例 9

73: PUSH20
PUSH(uint160)
pushes a 20-byte value onto the stack

<address>

FF: SELFDESTRUCT
selfdestruct(address(addr))
sends all funds to addr and pre-Cancun hardfork, EIP-7680: destroys the contract



案例 9

```
{
  // JSON-RPC method for sending transaction
  "method": "eth_sendTransaction",

  // Transaction parameters
  "params": [{
    // Sender's Ethereum address
    "from":
"0x2b7efe7c543727dd516a02e1dbe3d8a6cffae5e7",

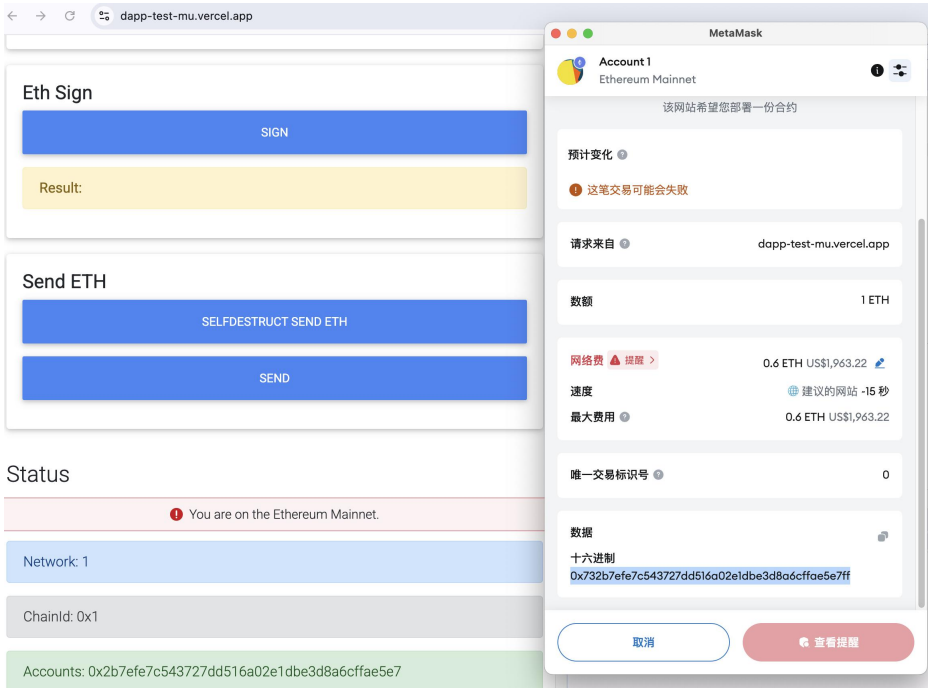
    // Recipient's address (0 indicates contract creation)
    "to": 0,

    // Gas price in wei (10 Gwei)
    "gasPrice": "0x09184e72a000",

    // Gas limit (60,000)
    "gas": "0xea60",

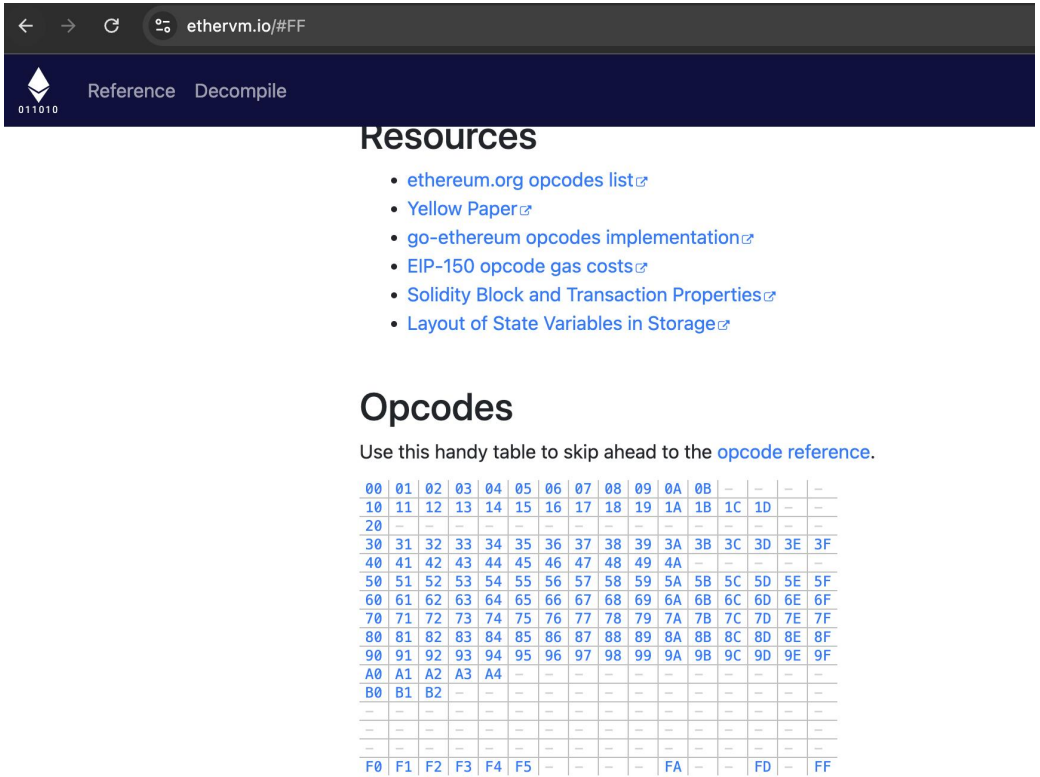
    // Value in wei (1 ETH)
    "value": "0xde0b6b3a7640000",

    // Contract data/input data
    "data":
"0x732b7efe7c543727dd516a02e1dbe3d8a6cffae5e7ff"
  }]
}
```



案例 9

- https://ethervm.io





Official Website
https://slowmist.com

Email
team@slowmist.com

X (Twitter)
@SlowMist_Team

GitHub
https://github.com/slowmist

Medium
https://slowmist.medium.com